

BUILD WEEK 3 // EXTRA 1

NetRebels

Mydoom

Traccia Extra 1 - Sorgente del Malware
Analisi storica e tecnica del worm Mydoom
sulla base di fonti pubbliche documentate

Malware Analysis | Mydoom / W32.MyDoom@mm / Novarg / Shimgapi

CORSO	Cybersecurity & Ethical Hacking - 2026
ISTITUTO	Epicode
GRUPPO	NetRebels
TIPO DI ESERCIZIO	Analisi Malware Mydoom
DATA	24 Giugno 2026



00

Indice

01 Introduzione

02 Obiettivi

03 Cronologia degli Eventi (Gennaio - Marzo 2004)

04 Analisi Tecnica del Comportamento (da Fonti Pubbliche)

4.1 Meccanismo di Infezione e Mascheramento

4.2 Raccolta degli Indirizzi e Motore di Mass-Mailing

4.3 Tecniche di Evasione e Offuscamento

4.4 Componente Backdoor / Proxy

4.5 Propagazione Secondaria via Rete P2P (Kazaa)

4.6 Modulo Denial-of-Service

4.7 Logica Temporale e Comportamento Anti-Rimozione

05 Confronto Sintetico: Mydoom.A vs Mydoom.B

07 Attribuzione: un Mistero Ancora Aperto

08 Eredità': Varianti Successive e Botnet 'Doomjuice'

09 Lezioni di Difesa e Indicatori Storici

11 Conclusioni

01

Introduzione

Mydoom (noto anche come W32.MyDoom@mm, Novarg o Shimgapi) e' un worm per Microsoft Windows individuato per la prima volta il 26 gennaio 2004. E' diventato il worm a diffusione via e-mail piu' rapida della storia, superando i record precedenti stabiliti da ILOVEYOU e Sobig, un primato che secondo diverse fonti di settore non e' mai stato battuto.

Questo report ricostruisce il profilo storico del worm sulla base di fonti pubbliche documentate (analisi di vendor di sicurezza, cronologie dell'epoca e retrospettive successive), come riferimento per il lavoro di analisi critica condotto nelle fasi precedenti di questa esercitazione.

02

Obiettivi

- Ricostruire la cronologia degli eventi principali legati alla diffusione di Mydoom.
- Descrivere il meccanismo di propagazione e la componente backdoor del worm.
- Confrontare le caratteristiche delle due varianti principali, Mydoom.A e Mydoom.B.
- Riepilogare le questioni ancora aperte, in particolare l'attribuzione dell'autore.

03

Cronologia degli Eventi

La tabella seguente ricostruisce i principali eventi legati alla diffusione di Mydoom tra gennaio e marzo 2004.

Data	Evento
26 gen 2004	Mydoom.A viene individuato per la prima volta, intorno alle 8:00 EST (13:00 UTC); nel giro di poche ore rallenta la velocità media di Internet di circa il 10%.
27 gen 2004	SCO Group offre una ricompensa di 250.000 dollari per informazioni sull'autore; FBI e Secret Service avviano le indagini.
28 gen 2004	Viene scoperta la seconda variante, Mydoom.B, che aggiunge Microsoft.com come bersaglio e blocca l'accesso a numerosi siti antivirus; in questa fase il worm arriva a rappresentare una quota molto rilevante del traffico email globale.
29 gen 2004	Anche Microsoft offre una ricompensa (secondo alcune fonti elevata fino a 500.000 dollari) per l'identificazione dell'autore.
1 feb 2004	Attivazione del payload DDoS di Mydoom.A contro il sito web di SCO Group (www.sco.com), che va offline per un periodo prolungato.
3 feb 2004	Attivazione del payload DDoS di Mydoom.B contro Microsoft.com; l'impatto risulta limitato grazie alle difese predisposte e a una diffusione minore della variante B.
12 feb 2004	Mydoom.A smette di auto-propagarsi per design, ma non si disinstalla: la backdoor resta attiva sui sistemi infetti.
1 mar 2004	Anche Mydoom.B smette di diffondersi; poco dopo lo stesso botnet viene riutilizzato per un nuovo attacco contro Microsoft, soprannominato 'Doomjuice'.

04

Analisi Tecnica del Comportamento

Questa sezione ricostruisce in maggiore dettaglio il funzionamento interno di Mydoom.A/B, organizzato per moduli funzionali, sulla base delle analisi tecniche pubblicate all'epoca da vendor di sicurezza e centri di analisi (Symantec, Microsoft Security Intelligence, F-Secure, documenti SANS/GIAC). L'obiettivo e' evidenziare chiaramente comportamento e funzionamento del worm cosi' come storicamente documentato, non fornire istruzioni per la sua ricostruzione.

• 4.1 Meccanismo di Infezione e Mascheramento

Il worm arrivava come allegato e-mail con estensioni quali .bat, .cmd, .exe, .pif, .scr o .zip, presentato come una notifica di errore di consegna ('Mail Delivery System', 'Test', 'Mail Transaction Failed') in diverse lingue. L'utente veniva indotto ad aprire l'allegato credendo di dover consultare un messaggio non recapitato; l'esecuzione dell'allegato attivava immediatamente il worm.

• 4.2 Raccolta degli Indirizzi e Motore di Mass-Mailing

A differenza di worm precedenti che si limitavano a sfruttare il client di posta installato, Mydoom integrava un proprio motore SMTP, rendendolo indipendente da Outlook o altri MUA. Gli indirizzi venivano raccolti dalla rubrica di Windows e da file locali con estensioni comuni per contenuti testuali/web; alcune varianti successive interrogavano anche motori di ricerca pubblici (Google, Yahoo, Lycos, AltaVista) per individuare ulteriori indirizzi associati ai domini gia' raccolti.

Per ampliare la lista di destinatari, il worm estraeva la sola porzione di dominio dagli indirizzi raccolti e generava nuovi indirizzi plausibili componendo nomi utente diversi sullo stesso dominio. Il campo 'From' veniva inoltre falsificato (spoofing) utilizzando un altro indirizzo tra quelli raccolti, complicando l'identificazione della macchina realmente infetta a partire dalla sola intestazione del messaggio.

Una caratteristica notata da piu' analisti e' l'esclusione deliberata di alcuni domini dall'invio: indirizzi di alcune universita' (tra cui MIT, Stanford, Rutgers, UC Berkeley) e di alcune aziende di sicurezza/software (Microsoft, Symantec) non venivano contattati, una scelta interpretata come tentativo di ridurre l'attenzione di ricercatori e istituzioni con elevata capacita' di analisi.

• 4.3 Tecniche di Evasione e Offuscamento

Il file eseguibile era compresso con UPX, un packer molto comune per l'epoca, e gran parte delle stringhe interne (messaggi, percorsi, nomi di file) era cifrata con il semplice algoritmo ROT13: una rotazione a 13 posizioni dell'alfabeto, sufficiente a impedire un riconoscimento immediato delle stringhe in chiaro da parte dei motori di scansione statica del 2004, ma triviale da invertire una volta nota la tecnica.

Per evitare esecuzioni multiple concorrenti sulla stessa macchina, il worm creava un mutex univoco con nome 'WebSipcSmtxSO': un secondo tentativo di esecuzione, trovando il mutex gia' presente, si interrompeva senza ripetere l'infezione.

• 4.4 Componente Backdoor / Proxy

Il payload principale depositava un file %System%\Shimgapi.dll e lo registrava tramite due chiavi di registro CLSID {E6FB5E20-DE35-11CF-9C87-00AA005127ED}\InProcServer32 e {35CEC8A3-2BE6-11D2-8773-92E220524153}\InProcServer32), facendo sì che Explorer.exe caricasse la DLL come proprio componente a ogni riavvio, anziché come processo separato visibile in Task Manager.

Secondo l'analisi tecnica di Symantec, la DLL agiva come server proxy, aprendo un intervallo di porte TCP in ascolto compreso tra 3127 e 3198 (non una singola porta fissa) e offrendo la capacità di scaricare ed eseguire file arbitrari da remoto. Questa componente, una volta installata, restava pienamente funzionante anche dopo la disattivazione delle routine di mass-mailing e DDoS, costituendo un punto di accesso residuo che sarebbe poi stato sfruttato da worm successivi come Doomjuice.

• 4.5 Propagazione Secondaria via Rete P2P (Kazaa)

Come canale di diffusione aggiuntivo, il worm individuava la cartella condivisa del client P2P Kazaa leggendo il valore di registro Dldir0 sotto HKEY_CURRENT_USER\Software\Kazaa\Transfer, e vi copiava una propria replica con nomi di file pensati per attirare altri utenti della rete (tipicamente camuffati da software popolari o crack), nella speranza che venissero scaricati ed eseguiti da terzi.

• 4.6 Modulo Denial-of-Service

Il modulo DoS si attivava in base alla data/ora di sistema della macchina infetta. Un dettaglio tecnico rilevante, documentato da Symantec, è che esisteva solo una probabilità del 25% che una data macchina infetta eseguisse effettivamente la routine di attacco al raggiungimento della data di trigger; questo comportamento limitò l'impatto reale del payload e in un primo momento indusse diversi analisti a dubitare della sua effettiva funzionalità.

Quando il modulo DoS si attivava, la macchina sospendeva temporaneamente l'invio di nuove e-mail per concentrare le risorse sull'attacco. Il meccanismo, descritto nel dettaglio da F-Secure per Mydoom.A, prevedeva l'avvio di 64 thread paralleli, ciascuno dei quali inviava ripetutamente una semplice richiesta HTTP 'GET / HTTP/1.1' verso il sito bersaglio a intervalli di circa 1024 millisecondi: un flood applicativo elementare, privo di qualunque exploit su vulnerabilità specifiche, mirato unicamente a saturare la capacità di gestione delle connessioni del webserver target.

Dettaglio sui bersagli DoS

Per **Mydoom.A** il bersaglio era www.sco.com, con trigger fissato all'1 febbraio 2004 alle 16:09:18 UTC; per **Mydoom.B** il medesimo meccanismo era ridiretto verso Microsoft.com a partire dal 3 febbraio 2004. Alcuni analisti dell'epoca hanno ipotizzato che il codice DoS della variante B fosse parzialmente difettoso, o persino un elemento di diversivo pensato per distogliere l'attenzione dalla reale funzione backdoor del worm.

• 4.7 Logica Temporale e Comportamento Anti-Rimozione

Entrambe le varianti integravano date di scadenza hardcoded per la sola componente di propagazione/DoS: il 12 febbraio 2004 per Mydoom.A e il 1 marzo 2004 per Mydoom.B. Superata tale data il worm cessava di inviare nuove e-mail e di tentare l'attacco, ma non si disinstallava: la componente backdoor restava attiva indefinitamente, salvo rimozione manuale o tramite strumento antivirus.

Mydoom.B aggiungeva inoltre una funzione di interferenza con la bonifica: sovrascriveva il file hosts locale per bloccare la risoluzione dei nomi di dominio di oltre sessanta siti di sicurezza/antivirus (impedendo l'accesso a

strumenti di rimozione e aggiornamenti) e, come effetto collaterale, anche di alcuni domini di advertising online. La persistenza al riavvio era garantita da una voce nel registro di avvio automatico (valore 'TaskMon' nelle chiavi Run di HKLM/HKCU), rimossa esplicitamente nelle istruzioni di disinfezione pubblicate dai vendor.

05

Confronto Sintetico: Mydoom.A vs Mydoom.B

Riepilogando quanto descritto nella sezione precedente, le due varianti principali condividevano il medesimo nucleo (mass-mailing, backdoor, propagazione P2P) ma differivano nel bersaglio del payload DoS e in alcune funzioni accessorie:

- **[V] Mydoom.A - bersaglio SCO Group**

Payload DoS verso www.sco.com, trigger 1 febbraio 2004 16:09:18 UTC, esecuzione effettiva stimata nel 25% delle macchine infette al momento del trigger. Cessazione della propagazione il 12 febbraio 2004, backdoor persistente.

- **[V] Mydoom.B - bersaglio Microsoft e siti antivirus**

Stesso meccanismo di payload DoS ridiretto verso Microsoft.com (trigger 3 febbraio 2004), con l'aggiunta del blocco via file hosts di oltre sessanta siti di sicurezza. Cessazione della propagazione il 1 marzo 2004, backdoor persistente. Diffusione complessiva inferiore rispetto alla variante A.

07

Attribuzione: un Mistero Ancora Aperto

Nonostante le indagini di FBI, Secret Service e delle principali aziende di sicurezza informatica, l'autore di Mydoom non e' mai stato identificato con certezza. Le prime ipotesi suggerivano un collegamento con un sostenitore del software libero, come ritorsione contro le note vicende legali di SCO Group contro la comunita' Linux; questa teoria fu pero' presto respinta dagli analisti, che attribuirono piu' plausibilmente l'origine del worm a gruppi di cybercriminali organizzati, probabilmente a scopo di lucro tramite l'invio massivo di spam.

Il worm conteneva un messaggio di testo ("Andy; I'm just doing my job, nothing personal, sorry") che ha alimentato la teoria secondo cui l'autore fosse stato pagato da uno spammer per realizzarlo. Diverse aziende di sicurezza ipotizzarono, su base circostanziale, una possibile origine russa, ma l'identita' reale resta a oggi sconosciuta. Il nome stesso 'Mydoom' fu coniato da Craig Schmugar di McAfee dopo aver notato la stringa 'mydom' all'interno del codice.

08

Eredita': Varianti Successive e Botnet 'Doomjuice'

Dopo la fine della fase di propagazione attiva delle varianti A e B, lo stesso parco di macchine infette (rimaste compromesse tramite la backdoor) venne riutilizzato per un nuovo attacco DDoS contro Microsoft, soprannominato 'Doomjuice', anch'esso respinto dalle difese predisposte dall'azienda.

Nei mesi successivi emersero numerose altre varianti minori; una di queste, nel luglio 2004, fu associata a un attacco che causò l'indisponibilità temporanea di motori di ricerca come Google, Lycos e AltaVista. Secondo alcune analisi di settore (es. Unit 42, 2019), tracce e varianti derivate da Mydoom risultavano ancora rilevabili nel traffico e-mail globale anni dopo l'epidemia originale, seppure con un'incidenza ormai marginale.

09

Lezioni di Difesa e Indicatori Storici

Dal profilo di Mydoom emergono alcune lezioni di difesa ancora rilevanti oggi:

- **Filtraggio e-mail:** la maggior parte delle infezioni richiedeva l'apertura manuale di un allegato; la formazione degli utenti e il filtraggio degli allegati restano una prima linea di difesa essenziale.
- **Monitoraggio di rete:** un'impennata anomala di traffico SMTP in uscita o di connessioni verso una singola destinazione e' un indicatore tipico di un worm mass-mailer o di un attacco DDoS distribuito in corso.
- **Persistenza delle backdoor:** anche dopo la cessazione della fase di propagazione attiva di un worm, le backdoor installate possono restare attive; una bonifica efficace richiede la rimozione esplicita della componente di accesso remoto, non solo del componente di diffusione.
- **Aggiornamento delle firme:** la capacita' di Mydoom.B di bloccare l'accesso ai siti antivirus dimostra l'importanza di canali di aggiornamento ridondanti per gli strumenti di sicurezza.

11

Conclusioni

Mydoom resta, oltre vent'anni dopo la sua comparsa, un caso di studio fondamentale per comprendere come un worm relativamente semplice dal punto di vista tecnico (nessun exploit sofisticato, nessuna offuscazione avanzata) possa raggiungere un impatto globale enorme semplicemente sfruttando comportamenti utente predicibili e un'infrastruttura di sicurezza dell'epoca ancora immatura.

Il profilo ricostruito in questo report fornisce la base storica di riferimento per le fasi successive dell'esercitazione, in particolare per valutare in modo critico qualunque nuova variante segnalata, confrontandone il comportamento osservato con quello documentato per il campione originale.

Documento redatto a scopo didattico -- Cyber Security & Ethical Hacking, EPICODE. Analisi basata su fonti pubbliche documentate.